

Security+ 3.4 · Resiliency

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 3.4** —
Resiliency (9:42) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Survive failure: RAID 1 (mirror), RAID 5 (parity), RAID 6 (double parity); clustering (failover); load balancing; site: hot (active replica), cold (empty room); multi-cloud/region survives vendor failure.

High-Yield Core Concepts Tested on Exam

- RAID 1 = mirror; RAID 5 = parity; RAID 6 = double parity
- Hot site = active duplicate; cold = physical infrastructure only

Exam Tips & Classic Scenarios

- 'maintains uptime through component failure' = redundancy/failover

Typical Exam Scenario: 'entire datacenter failed and service continued' = multi-region/resiliency.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 3.4 — Resiliency)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Which S3 feature ensures 99.99999999% (11 nines) durability?

- A)** Encryption at rest
- B)** Versioning and cross-AZ replication
- C)** Lifecycle policies
- D)** Transfer Acceleration

2. Storing backups in a geographically separate location to survive a physical disaster is:

- A)** Redundancy / offsite
- B)** Least privilege
- C)** Non-repudiation
- D)** Obfuscation

3. What is vertical scalability (scale up)?

- A)** Add more instances
- B)** Increase resources (CPU/RAM) of the existing instance
- C)** Distribute load across regions
- D)** Implement auto scaling

4. Corporate scenario (Resiliency): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.4), an analyst evaluates the following technical requirement: 'RAID 1 = mirror; RAID 5 = parity; RAID 6 = double parity'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: RAID 1 = mirror; RAID 5 = parity; RAID 6 = double parity.

5. Corporate scenario (Resiliency): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.4), an analyst evaluates the following technical requirement: 'Hot site = active duplicate; cold = only physical infrastructure'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Hot site = active duplicate; cold = only physical infrastructure...

6. Corporate scenario (Resiliency): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.4), an analyst evaluates the following technical requirement: 'maintains uptime through component failure'=redundancy/failover'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'maintains uptime through component failure'=redundancy/failover...

7. Corporate scenario (Resiliency): During a security review and compliance audit for the CompTIA Security+ exam (SY0-701, Section 3.4), an analyst evaluates the following technical requirement: 'entire datacenter failed and service continued' = multi-region/resiliency'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'entire datacenter failed and service continued' = multi-region/resiliency...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Resiliency): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.4), an analyst evaluates the following technical requirement: 'RAID 1 = mirror; RAID 5 = parity; RAID 6 = double parity'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: RAID 1 = mirror; RAID 5 = parity; RAID 6 = double parity...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

9. Corporate scenario (Resiliency): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.4), an analyst evaluates the following technical requirement: 'Hot site = active duplicate; cold = physical infrastructure only'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Hot site = active duplicate; cold = physical infrastructure only...
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Resiliency): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.4), an analyst evaluates the following technical requirement: 'maintains uptime through component failure'=redundancy/failover'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'maintains uptime through component failure'=redundancy/failover...

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Versioning and cross-AZ replication.

✓ **Why it is correct:** The correct answer is 'Versioning and cross-AZ replication'. Amazon S3 provides 99.999999999% (11 nines) durability because it stores each object redundantly across multiple facilities within a region, distributed across at least three Availability Zones (AZs). Versioning protects against accidental deletions and overwrites by keeping previous versions of objects, while cross-AZ replication (and optionally cross-region replication) ensures data exists in physically separate locations. This combination of geographic redundancy and version history underpins the 11 nines durability. CompTIA addresses durability as the probability that data will not be lost, and in S3 this is achieved through automatic replication across AZs and versioning.

✗ **Why the others are wrong:**

- *Encryption at rest:* Encryption at rest protects data from unauthorized access when stored, using keys managed by S3 (SSE-S3), KMS (SSE-KMS), or the customer (SSE-C). It is a confidentiality measure, not durability. It does not prevent data loss from hardware failure, accidental deletion, or corruption; therefore, it is not the feature that guarantees 11 nines of durability.
- *Lifecycle policies:* Lifecycle policies are rules that automate the transition of objects between storage classes (e.g., Standard to Glacier) or expiration/deletion after a period. They help optimize costs and manage data lifecycle, but do not increase S3's intrinsic durability. In fact, misconfigured policies can lead to data deletion, reducing availability. It is not the mechanism that ensures 11 nines.
- *Transfer Acceleration:* Transfer Acceleration is a feature that uses CloudFront edge locations to accelerate long-distance uploads and downloads, improving transfer performance. It has no relation to durability or storage redundancy; it is a network optimization. Therefore, it does not contribute to the 99.999999999% durability guarantee.

2) A — Redundancy / offsite.

✓ **Why it's correct:** Redundancy / offsite refers to the practice of keeping backup copies in a location geographically separate from the primary facility, so that a physical disaster (fire, flood, earthquake) does not simultaneously destroy the original data and the copies. This is part of SY0-701 objective 3.4 (resilience and recovery) and 4.1 (backup controls). The question describes exactly storing backups in a geographically separate location to survive a physical disaster, which is the definition of offsite redundancy.

✗ **Why the others are wrong:**

- *Least privilege:* The principle of least privilege dictates that users, processes, and systems receive only the accesses necessary to perform their functions, and nothing more. It is an access control that reduces the attack surface and the impact of compromises. It has no relation to storing backups in a separate location; it is an authorization principle, not business continuity or disaster recovery. The question asks for a geographically separate backup strategy, not a privilege policy.
- *Non-repudiation:* Non-repudiation is the assurance that a party cannot deny the authorship of an action or transaction, typically implemented through digital signatures and auditable logs. It is a security principle related to integrity and authenticity of transactions, not backup storage. The question deals with surviving a physical disaster through offsite backup, which is not addressed by non-repudiation.
- *Obfuscation:* Obfuscation is the technique of making code or data difficult to understand, aiming to hinder analysis by attackers or protect intellectual property. It does not provide redundancy or protection against physical disasters. The question asks for a backup strategy in a separate location to survive a disaster, which is not a function of obfuscation.

3) B — Increase resources (CPU/RAM) of the existing instance.

✓ **Why it's correct:** The correct answer is 'Increase resources (CPU/RAM) of the existing instance'. Vertical scalability, also called scale up, consists of increasing the capacity of a single server or instance by adding more hardware resources, such as CPU, RAM, storage, or bandwidth. The goal is to make the existing machine more powerful to handle greater load. It is a process generally limited by the maximum resources a single machine can support and may require a reboot. CompTIA defines vertical scalability as increasing the capacity of an existing resource, as opposed to horizontal, which adds more nodes.

✗ **Why the others are wrong:**

- *Add more instances:* Adding more instances is horizontal scalability (scale out), which increases capacity by distributing load across multiple servers or nodes. It is the opposite of vertical, which focuses on strengthening a single instance. Therefore, it does not describe scale up.
- *Distribute load across regions:* Distributing load across regions is a geographic scalability and high availability strategy, generally associated with global load balancing and cross-region replication. It is not the concept of vertical scalability, which acts on a single server by increasing its resources.
- *Implement auto scaling:* Auto scaling is a mechanism that automatically adjusts the number of instances (horizontal scalability) based on metrics such as CPU or traffic. Although it can include scale up and scale down policies, the term 'auto scaling' typically refers to horizontal elasticity, not increasing resources of an existing instance. Therefore, it does not define vertical scalability.

4) D — Implement the corresponding solution: RAID 1 = mirror; RAID 5 = parity; RAID 6 = double parity..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.4 (Resiliency): RAID 1 = mirror; RAID 5 = parity; RAID 6 = double parity. RAID 1 duplicates data across two drives for redundancy; RAID 5 uses distributed parity to survive one drive failure; RAID 6 uses two parity blocks to survive two simultaneous drive failures.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) D — Implement the corresponding solution: Hot site = active duplicate; cold = only physical infrastructure....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.4 (Resiliency): Hot site = active duplicate; cold = only physical infrastructure. A hot site is a fully operational duplicate of the primary site, while a cold site provides only basic infrastructure and requires setup.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are

administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) D — Implement the corresponding solution: 'maintains uptime through component failure'=redundancy/failover....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.4 (Resiliency): 'maintains uptime through component failure'=redundancy/failover. Redundancy involves duplicating critical components or systems so that if one fails, another can take over (failover), ensuring continuous availability.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) A — Implement the corresponding solution: 'entire datacenter failed and service continued' = multi-region/resiliency....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.4 (Resiliency): 'entire datacenter failed and service continued' = multi-region/resiliency.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who made critical changes or malicious commands.

8) B — Implement the corresponding solution: RAID 1 = mirror; RAID 5 = parity; RAID 6 = double parity....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.4 (Resiliency): RAID 1 = mirror; RAID 5 = parity; RAID 6 = double parity. RAID 1 mirrors data across two or more disks, providing redundancy but no parity. RAID 5 uses distributed parity, allowing recovery from a single disk failure. RAID 6 uses two parity blocks, allowing recovery from two simultaneous disk failures. These configurations enhance availability and fault tolerance.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks

compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) C — Implement the corresponding solution: Hot site = active duplicate; cold = physical infrastructure only....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.4 (Resiliency): Hot site = active duplicate; cold = physical infrastructure only. A hot site is a fully operational offsite data center with hardware, software, and near real-time data replication, enabling rapid failover. A cold site provides only basic physical infrastructure (power, cooling, network connectivity) without pre-installed hardware or data, requiring significant time to become operational.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) D — Implement the corresponding solution: 'maintains uptime through component failure'=redundancy/failover....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.4 (Resiliency): 'maintains uptime through component failure'=redundancy/failover.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

